

SIMATS ENGINEERING

ASSESSMENT TOOL 2

COURSE NAME: Ethical Hacking COURSE CODE: ITA14

COURSE OUTCOME COVERED

CO2: Foot printing Tools: Conducting Competitive Intelligence, DNS Zone Transfers, Introduction to Social Engineering: Social Engineering Attacks and Countermeasures. (BT4)

Assessment Tool Weightage: 30%

Duration: 90 min Total Marks: 50 Social Engineering Simulation

Questions

1. As a Security Analyst, perform an OSINT-based email enumeration assessment on the target domain **tesla.com** using **theHarvester** in Kali Linux. Collect publicly available email addresses, subdomains, hosts, and IP addresses associated with the organization. Categorize the discovered email addresses into likely roles such as Support, Sales, Human Resources, Administration, and Technical Teams. Analyze how the gathered information could assist an attacker during the reconnaissance phase and explain how it could be used for spear-phishing, credential harvesting, and impersonation attacks. Finally, recommend at least five countermeasures to reduce information leakage and social engineering risks, and submit a report with screenshots, commands executed, findings, risk analysis, and recommendations. **(20 Marks)**

Commands:

- theHarvester --help
- mkdir ~/Tesla_OSINT
- cd ~/Tesla_OSINT
- theHarvester -d tesla.com -b crtsh
- theHarvester -d tesla.com -b bing
- theHarvester -d tesla.com -b bing -f tesla_osint_bin

Observations:

- OSINT Scan: The tesla.com domain was successfully searched using theHarvester.
- Hosts Found: Three hosts were identified — inside.tesla.com, parts.tesla.com, and shop.tesla.com.
- Email Addresses: No email addresses were found from the selected Bing source.
- Other Information: No people or IP addresses were identified in the search.
- Report Generation:

XML and JSON files were successfully generated containing the scan results.

Possible Attacks:

- Spear-Phishing: Use public information to create targeted phishing messages.
- Credential Harvesting: Trick users into providing login credentials.
- Impersonation: Pretend to be a trusted employee or department.
- Reconnaissance: Use discovered hosts to understand the organization's infrastructure.

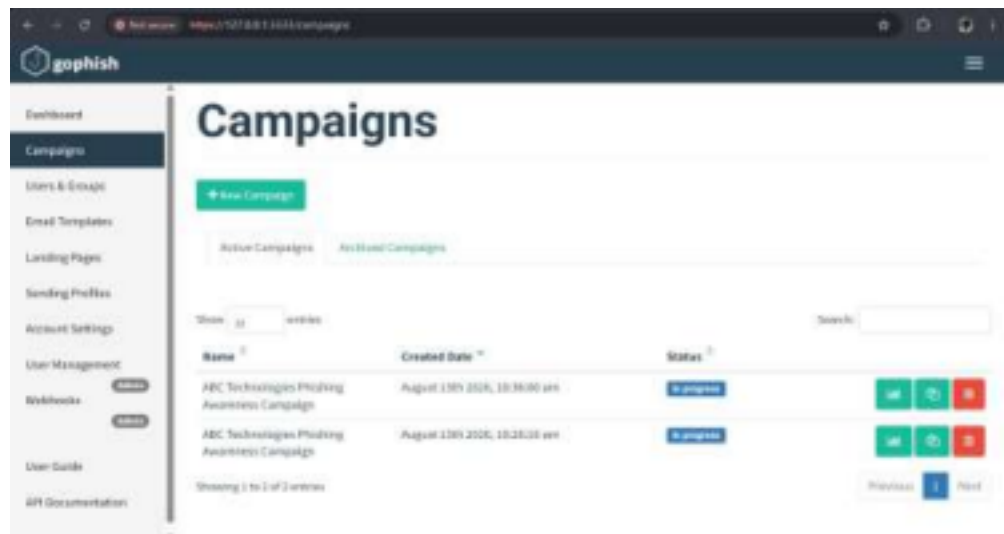
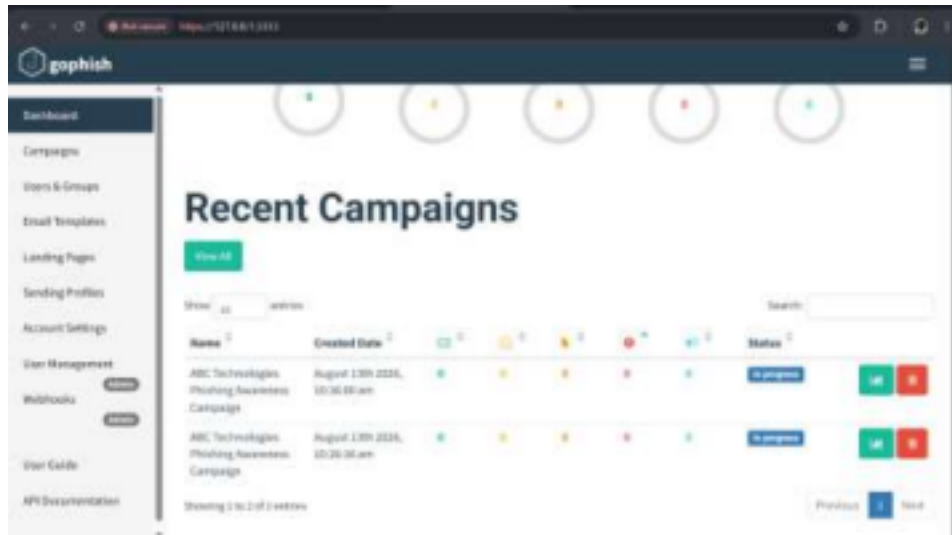
Further Attacks: Use the gathered information to identify potential targets. **Security**

Recommendations:

- Limit public information about employees and infrastructure.
- Review exposed subdomains and remove unnecessary records.
- Enable MFA for important accounts.
- Use SPF, DKIM, and DMARC to prevent email spoofing.
- Conduct regular OSINT reviews to identify information leakage.



- Scan email attachments for malware.
- Block dangerous file types and suspicious attachments.
- Use URL filtering to detect and block malicious links.
- Enable MFA to protect accounts from stolen credentials.
- Provide a phishing-reporting option for employees.
- Conduct regular security awareness training and phishing simulations.



3. Using Nmap Aggressive Scan (-A) on scanme.nmap.org, gather detailed information about the target including operating system details, open ports, and service versions. Assume you are an attacker and describe how the collected information could be leveraged to conduct a social engineering attack against the IT support team. Prepare a report explaining the attack methodology and defensive recommendations.(10 Marks)

Commands:

- `nmap [Target Domain]`
- `nmap -A [Target Domain]`
- `nmap -A [Target Domain] -oN nmap_scan_report.txt`

- cat nmap_scan_report.txt

Observations:

- Aggressive Scan: Detailed information about the target was collected using Nmap.
- Open Ports: Open network ports and running services were identified.
- Service Versions: The versions of the detected services were identified.
- OS Detection: The target operating system was identified or estimated.
- Attack Surface: The scan revealed information that could help identify potential security weaknesses.

Possible Attacks:

- Reconnaissance: Gather information about the target system.
- Social Engineering: Use technical details to create convincing messages.
- Impersonation: Pretend to be IT support or a trusted employee.
- Credential Theft: Trick users into revealing login details.
- Targeted Attacks: Use service information to identify potential weaknesses.

Security Recommendations:

- Limit exposed services by closing unnecessary ports.
- Keep services updated with the latest security patches.
- Use firewalls to restrict access to sensitive services.
- Train IT staff to recognize impersonation and social-engineering attempts.

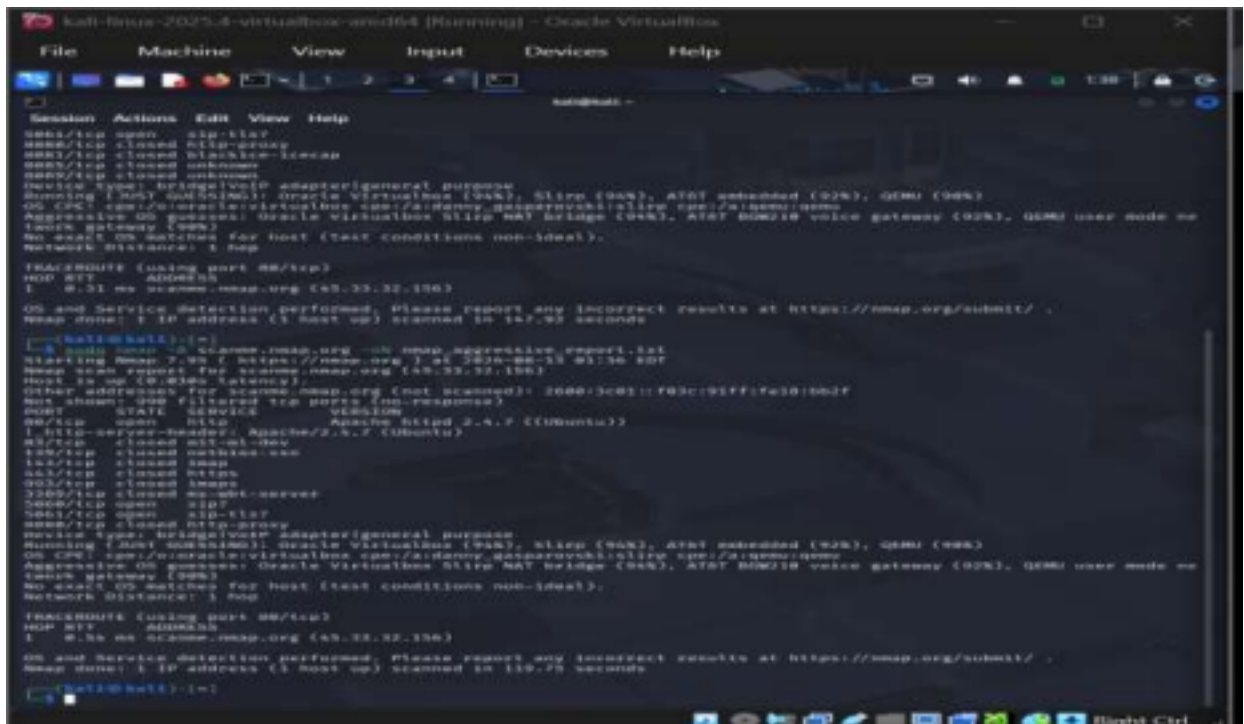
Verify identities before sharing credentials or sensitive information.

- Enable MFA for administrative and support accounts.
- Monitor network activity for unusual scanning or access attempts.

```

kali@kali:~$ cat nmap_scan_report.txt
Nmap scan report for 192.168.1.100
Host is up (0.0000s latency).
Other addresses for 192.168.1.100 (not scanned): 2000:3c01:f03c:01ff:f010:b02f
Nmap scan report for 192.168.1.100
Host is up (0.0000s latency).
Other addresses for 192.168.1.100 (not scanned): 2000:3c01:f03c:01ff:f010:b02f

```



Code of Conduct:

I G. NITHYA SREE certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment.
 I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student:

RUBRICS FOR CALCULATION

Social Engineering Simulation					
Criteria	Weightage (%)	Level 4 (Exemplary)	Level 3 (Proficient)	Level 2 (Developing)	Level 1 (Beginning)
Understanding of Social Engineering Scenario	20%	Demonstrates a comprehensive understanding of the social engineering scenario, attack techniques, and security context	Demonstrates good understanding with minor omissions.	Shows partial understanding but misses important aspects of the scenario.	Fails to understand or incorrectly interprets the social engineering scenario.
Identification of Attack and Vulnerabilities	20%	Correctly identifies the attack type, exploited vulnerabilities, and affected assets with complete accuracy	Correctly identifies most attack techniques with minor errors.	Identifies only some attack methods and vulnerabilities.	Unable to identify the attack type or associated vulnerabilities.

Application of Security Concepts and Countermeasures	25%	Effectively applies cybersecurity concepts and recommends appropriate preventive, detective, and corrective countermeasures.	Applies relevant concepts with minor errors and recommends suitable countermeasures.	Applies concepts partially with limited recommendations.	Unable to apply relevant cybersecurity concepts or recommend suitable countermeasures.
Risk Analysis and Decision Making	20%	Performs logical risk analysis, evaluates business impact, and provides well justified security decisions.	Provides reasonable analysis with adequate justification.	Performs limited analysis with weak justification.	Provides no meaningful analysis or justification.
Clarity, Documentation and Technical Presentation	15%	Response is well organized, technically accurate, professionally documented, and logically presented.	Response is clear with minor documentation or presentation issues.	Response lacks organization and contains technical inaccuracies.	Response is poorly organized, incomplete, and difficult to understand.